

INTERVIEW PREPARATION GUIDE

Network Security Analyst

Complete Interview Q&A; Guide

Based on: IT Executive – Network Security | Ami Polymer JD

50+ Questions

10 Sections

Real Examples

Interview Tips

Prepared by Akhilesh Choudhary | TechShiksha | akhileshchaudhari.com

Table of Contents

01	Networking Fundamentals	6 Qs
	<i>TCP/IP Model, DNS, DHCP, DORA Process, Subnetting, LAN/WAN, Traffic Monitoring</i>	
02	Firewall & VPN	5 Qs
	<i>Firewall Types, FortiGate Policy, IPSec vs SSL VPN, IDS/IPS, Network Segmentation</i>	
03	Endpoint Security & Antivirus	3 Qs
	<i>EDR vs AV, Patch Management, Malware Incident Response</i>	
04	User Access Management	4 Qs
	<i>Active Directory, RBAC, Least Privilege, MFA, Offboarding Security</i>	
05	Security Monitoring & Incident Response	3 Qs
	<i>SIEM, PICERL Framework, Log Analysis, Threat Detection</i>	
06	Vulnerability Assessment & Pen Testing	3 Qs
	<i>VA vs PT, Common Vulnerabilities, Nmap Commands, CVE/CVSS</i>	
07	Compliance & Audit	3 Qs
	<i>ISO 27001, Security Documentation, GMP / 21 CFR Part 11</i>	
08	Security Policies, Backup & DR	3 Qs
	<i>3-2-1 Backup Rule, BCP vs DR, RTO/RPO, Policy Enforcement</i>	
09	HR & Behavioral Questions	4 Qs
	<i>Tell Me About Yourself, STAR Method, Work-Life Balance, Staying Updated</i>	
10	Rapid Fire Q&A;	16 Qs
	<i>HTTP vs HTTPS, Ports, ARP, Zero Trust, DLP, Honeypot, Encryption, Ransomware...</i>	

01

Networking Fundamentals

Q1

TCP/IP model kya hota hai? Uske 4 layers explain karo.

✓ ANSWER

TCP/IP ek 4-layer communication framework hai jo internet communication govern karta hai. (1) Network Access Layer – Physical data transmission; Ethernet, MAC address, switches. (2) Internet Layer – IP addressing aur routing; IP, ICMP, ARP protocols. (3) Transport Layer – End-to-end reliable (TCP) ya fast (UDP) data delivery. (4) Application Layer – User-facing protocols: HTTP, FTP, DNS, SMTP, SSH. OSI model se comparison: TCP/IP 4 layers vs OSI 7 layers (Physical, Data Link, Network, Transport, Session, Presentation, Application).

■ EXAMPLE

Jab aap browser mein google.com type karte ho – App layer HTTP request banata hai □ Transport layer TCP establish karta hai □ Internet layer routing □ Network layer physical frame bheji.

□ INTERVIEW TIP: OSI vs TCP/IP fark zaroori hai – interviewer commonly compare karne ko kahta hai.

Q2

DNS kya hai aur yeh kaise kaam karta hai? Important DNS records bhi batao.

✓ ANSWER

DNS (Domain Name System) human-readable domain names (google.com) ko IP addresses (142.250.x.x) mein convert karta hai. Resolution Steps: Browser cache □ OS cache □ Local DNS resolver □ Root DNS □ TLD (.com) □ Authoritative DNS □ IP return. Key DNS Records: • A Record – Domain □ IPv4 address • AAAA – Domain □ IPv6 address • MX – Mail server • CNAME – Alias (www □ main domain) • PTR – Reverse DNS (IP □ Domain) • TXT – Verification (SPF, DKIM)

■ EXAMPLE

Internal AD-integrated DNS: User types \\fileserver, DNS resolves IP □ seamless file share access.

□ INTERVIEW TIP: Troubleshooting commands: nslookup domain.com | dig domain.com | ipconfig /flushdns

Q3

DHCP kya hai? DORA process step-by-step explain karo.

✓ ANSWER

DHCP (Dynamic Host Configuration Protocol) automatically network configuration assign karta hai: IP address, Subnet Mask, Default Gateway, DNS Server. DORA Process (UDP, Port 67 server / 68 client):

- D – Discover: Client broadcast karta hai "koi DHCP server hai?"
- O – Offer: Server available IP offer karta hai
- R – Request: Client selected IP accept karta hai
- A – Acknowledge: Server lease confirm karta hai (8 hrs / 24 hrs) Lease renewal 50% time par hoti hai automatically.

■ EXAMPLE

Office mein naya PC lagaya – automatic IP mila. Agar nahi mila: check karo DHCP scope exhausted toh nahi, server running hai ya nahi.

□ INTERVIEW TIP: DHCP Snooping = rogue DHCP server attack prevent karta hai. Yeh mention karo – extra marks milenge.

Q4

Subnetting kya hai? 192.168.1.0/24 ko 4 subnets mein divide karo.

✓ ANSWER

Subnetting ek large network ko chhote isolated segments mein divide karna hai. Yeh security, traffic control aur IP utilization improve karta hai. 192.168.1.0/24 □ 4 subnets ke liye 2 bits borrow karo □ /26

- Subnet 1: 192.168.1.0/26 | Hosts: .1 – .62 | Broadcast: .63
- Subnet 2: 192.168.1.64/26 | Hosts: .65 – .126 | Broadcast: .127
- Subnet 3: 192.168.1.128/26 | Hosts: .129 – .190 | Broadcast: .191
- Subnet 4: 192.168.1.192/26 | Hosts: .193 – .254 | Broadcast: .255

Har subnet mein 62 usable hosts hote hain.

■ EXAMPLE

HR (VLAN 10), Finance (VLAN 20), IT (VLAN 30), Guest (VLAN 40) – alag subnets se traffic isolation aur security.

□ INTERVIEW TIP: VLSM (Variable Length Subnet Masking) bhi jaano – different departments ke liye different size subnets.

Q5

LAN, MAN aur WAN mein kya fark hai?

✓ ANSWER

- LAN (Local Area Network): Single building/campus, high speed (1-10 Gbps), low latency, organization manage karta hai. Technologies: Ethernet, Wi-Fi.
- MAN (Metropolitan Area Network): City-level, multiple buildings connected, medium range. Technologies: Fiber, Metro Ethernet.
- WAN (Wide Area Network): Country/global level, ISP manage karta hai, relatively higher latency. Technologies: MPLS, Leased Line, SD-WAN, Internet VPN.

■ EXAMPLE

HO Mumbai + Branches Delhi/Pune = WAN. Building ke andar floors ka network = LAN. City mein 3 branches connected = MAN.

□ INTERVIEW TIP: SD-WAN modern WAN solution hai – cost-effective, centrally managed. Mention karo to show awareness.

Q6

Network traffic monitor karne ke liye kaunse tools use karte ho?

✓ ANSWER

Monitoring Tools by Category: • Packet Analysis: Wireshark – deep packet capture aur inspection • Bandwidth/Device Monitoring: PRTG, SolarWinds – real-time graphs • Infrastructure Monitoring: Nagios, Zabbix – open-source, alerts • Flow Analysis: NetFlow/sFlow – who is sending traffic to where • Firewall Logs: FortiAnalyzer – FortiGate centralized log management • Network Discovery: Nmap – port scan, service detection • SIEM: Splunk, IBM QRadar – log correlation aur threat detection

■ EXAMPLE

Network suddenly slow hua □ Wireshark se capture kiya □ ek PC se massive traffic □ bot infection confirm □ isolate karke clean kiya.

□ INTERVIEW TIP: SIEM ka naam lena = advanced awareness dikhata hai. Always mention karo.

02

Firewall & VPN

Q7

Firewall kya hai? Types of Firewall explain karo.

✓ ANSWER

Firewall ek network security device hai jo traffic ko predefined rules ke basis par allow/block karta hai. Types: • Packet Filtering: IP/port basis, stateless, basic – oldest type • Stateful Inspection: Connection state track karta hai – more intelligent • Application/Proxy Firewall: Layer 7 content inspect karta hai • Next-Generation Firewall (NGFW): Deep Packet Inspection + IPS + App Control + SSL Inspection. FortiGate isi category mein. • WAF (Web Application Firewall): HTTP/HTTPS attacks ke liye (SQLi, XSS)

■ EXAMPLE

FortiGate 100F office mein: WAN se aane wali traffic – Antivirus scan □ IPS check □ Web Filter □ App Control □ phir allow/deny.

□ INTERVIEW TIP: NGFW vs Traditional ka fark bolna important hai – application visibility aur user identity awareness NGFW ki key differentiator hai.

Q8

FortiGate mein Security Policy kaise configure karte hain?

✓ ANSWER

FortiGate Policy Configuration Steps: 1. Policy & Objects □ Firewall Policy □ Create New 2. Incoming Interface: LAN | Outgoing Interface: WAN 3. Source: Address/Group (e.g., HR_Subnet) 4. Destination: all / specific server 5. Service: HTTP, HTTPS, DNS, Any 6. Action: ACCEPT / DENY 7. Security Profiles attach karo: – Antivirus Profile | IPS Profile – Web Filter Profile | Application Control 8. NAT: Enable (for internet access) 9. Logging: Enable "Log Allowed Traffic" Policy order matters – top se bottom match hota hai. "Implicit Deny All" last rule hota hai.

■ EXAMPLE

HR users ke liye social media block: Source=HR_VLAN, Action=ACCEPT, Web Filter=Block_Social applied □ Facebook automatically block.

□ INTERVIEW TIP: Unused/old firewall rules regular audit karo. Rule bloat = security risk + performance issue.

Q9

VPN kya hai? IPSec VPN aur SSL VPN mein kya fark hai?

✓ ANSWER

VPN (Virtual Private Network) public internet par ek encrypted tunnel create karta hai secure communication ke liye. IPSec VPN (Site-to-Site): • Two networks ko permanently connect karta hai • IKE Phase 1 (ISAKMP SA) + Phase 2 (IPSec SA) • Protocols: ESP (Encapsulating Security Payload), AH • Ports: UDP 500 (IKE), UDP 4500 (NAT-T) • Use case: Branch □ HO permanent connection SSL VPN (Remote Access): • Individual users ke liye, browser-based ya FortiClient app • Port: TCP 443 (firewall-friendly) • Use case: Work-from-home, travelling employees Split Tunneling: Sirf company traffic VPN se, baaki internet directly jata hai.

■ EXAMPLE

Branch Pune □ HO Mumbai = IPSec Site-to-Site. WFH employee = SSL VPN FortiClient.

□ INTERVIEW TIP: Weak VPN configs (IKEv1, DES encryption) avoid karo – IKEv2 + AES-256 use karo.

Q10

IDS aur IPS mein kya antar hai?

✓ ANSWER

IDS (Intrusion Detection System): • Sirf detect aur alert karta hai – traffic block nahi • Passive/out-of-band deployment • False positive = alert mila par attack nahi tha IPS (Intrusion Prevention System): • Detect + Block – inline deployment, real-time action • NGFW mein built-in hota hai (FortiGate IPS profile) Detection Methods: • Signature-Based: Known attack patterns match karta hai • Anomaly-Based: Normal behavior se deviation detect karta hai • Heuristic/AI: Pattern learning se unknown threats

■ EXAMPLE

FortiGate IPS profile: High severity = block, Medium = monitor. Signature update daily hoti hai via FortiGuard.

□ INTERVIEW TIP: False Positive vs False Negative concept clear rakhna – FP = legitimate block, FN = attack miss. Dono costly hain.

Q11

Network Segmentation kya hai aur isko kyun karte hain?

✓ ANSWER

Network Segmentation = ek network ko multiple isolated zones/VLANs mein divide karna.
 Benefits: • Breach Containment: Ek segment compromise = baaki safe • Performance: Chhota broadcast domain = less congestion • Compliance: PCI-DSS, HIPAA mandate segmentation • Access Control: Least privilege easier to enforce Implementation: • VLANs + managed switches • Inter-VLAN routing via firewall (Layer 3) • Zones: Internal LAN | DMZ | Guest WiFi | IoT | Servers Zero Trust: "Never trust, always verify" – even internal traffic verify karo.

■ EXAMPLE

Finance VLAN 10, HR VLAN 20, Servers VLAN 30, IoT VLAN 40. Finance ka printer server directly accessible nahi – firewall se controlled.

□ INTERVIEW TIP: Micro-segmentation aur ZTNA modern enterprise mein use hota hai – awareness dikhao.

03

Endpoint Security & Antivirus

Q12

EDR kya hai? Traditional Antivirus se kaise alag hai?

✓ ANSWER

Traditional Antivirus: • Signature-based: Known malware ki database se match • Reactive: Attack hone ke baad detect karta hai • Limited visibility: File scan tak simit EDR (Endpoint Detection & Response): • Behavior-based detection: Unknown threats bhi pakad sakta hai • Real-time endpoint activity monitoring • Automated response: Process kill, quarantine, isolate • Threat hunting aur forensic investigation • Timeline view: Attack kaise hua step-by-step Popular EDR Tools: CrowdStrike Falcon, Microsoft Defender for Endpoint, Sophos Intercept X, FortiEDR, SentinelOne XDR = EDR + Network + Cloud combined detection.

■ EXAMPLE

Ransomware: Signature match nahi tha (new variant) lekin EDR ne abnormal file encryption behavior detect kiya □ process kill □ attack stopped.

□ INTERVIEW TIP: XDR (Extended Detection & Response) next evolution hai – mention karna shows awareness of current trends.

Q13

Patch Management kya hai? Process aur importance explain karo.

✓ ANSWER

Patch Management = Software, OS, firmware ke security updates systematically apply karna.
 Process: 1. Asset Inventory – Kya patch karna hai jaano 2. Vulnerability Scan – Missing patches identify karo (Nessus/Qualys) 3. Prioritize – CVSS score ke hisaab se (Critical > Important > Moderate) 4. Test – Lab/staging environment mein pehle test karo 5. Deploy – Production rollout (maintenance window mein) 6. Verify – Rescan confirm karo patch applied 7. Document – Change log update karo Tools: WSUS (Windows), SCCM, ManageEngine Patch Manager Plus, Ansible Importance: 60%+ cyberattacks known vulnerabilities exploit karte hain jiske patches available hote hain.

■ EXAMPLE

WannaCry ransomware EternalBlue (MS17-010) exploit karta tha – patch 2 months pehle available tha. Unpatched systems ne \$8B+ damage suffer kiya.

□ INTERVIEW TIP: Zero-day = patch nahi mila yet. Compensating controls use karo: WAF rules, IPS signatures, network isolation.

Q14

Kisi user ka system malware se infected ho gaya – aap kya steps loge?

✓ ANSWER

Incident Response – Malware Handling: 1. ISOLATE: System ko network se immediately disconnect karo (physical cable ya NAC) 2. IDENTIFY: Malware type kya hai? (Ransomware, Trojan, Spyware, Worm?) 3. CONTAIN: Network mein spread toh nahi hua? Same subnet ke systems check karo 4. COLLECT EVIDENCE: Memory dump, log copy, screenshots before cleanup 5. ERADICATE: AV full scan, malicious processes kill, infected files remove 6. RECOVER: Clean backup se restore, ya fresh OS install 7. VERIFY: Rescan karo confirm clean system hai 8. DOCUMENT & REPORT: Incident ticket, root cause, timeline, lessons learned

■ EXAMPLE

User ne suspicious email attachment khola □ ransomware execute □ files encrypt hone lage □ Immediately network disconnect □ 2 hours mein backup se restore.

□ INTERVIEW TIP: Agar legal action possible ho toh chain of custody maintain karo – forensic copy pehle, phir cleanup. Original evidence tamper mat karo.

04

User Access Management & Active Directory

Q15

Active Directory kya hai? Security mein iska role kya hai?

✓ ANSWER

Active Directory (AD) Microsoft ka centralized directory service hai – users, computers, groups aur resources manage karta hai. Key Components: • Domain Controller (DC): AD database host karta hai • OU (Organizational Unit): Logical grouping (HR OU, IT OU) • Group Policy Objects (GPO): Settings centrally enforce karo • LDAP Protocol: Directory queries ke liye • Kerberos: Secure authentication protocol Security Features: • Centralized authentication (Single Sign-On) • Role-based access via Security Groups • GPO: Password policy, screen lock, USB disable, firewall on • Account lockout: 5 wrong attempts → lock • Audit logs: Login failures, privilege escalation

■ EXAMPLE

Naya employee join kiya → AD mein user create karo → Dept OU mein add → Finance_Group assign → GPO automatically apply → Permissions ready.

→ INTERVIEW TIP: AD attack vectors jaano: Pass-the-Hash, Kerberoasting, DCSync. Defense: Tiered admin model, Privileged Access Workstations (PAW).

Q16

RBAC aur Least Privilege Principle kya hai?

✓ ANSWER

RBAC (Role-Based Access Control): Users ko job role ke basis par permissions milti hain – individually nahi. Roles define karo → Permissions assign karo roles ko → Users ko roles assign karo Least Privilege Principle: Har user/process ko sirf utna hi access do jitna minimum zaroori ho unke kaam ke liye. Access Types: • Read | Read-Write | Full Control • Segregation of Duties: Finance approve + IT deploy – same person nahi PAM (Privileged Access Management): • Admin accounts separately manage karo • Just-in-time access: Zaroorat pe milta hai, kaam ke baad revoke • Session recording: Kya kiya track karo

■ EXAMPLE

Finance_ReadOnly group → payroll reports dekh sakta hai. Finance_Modify group → sirf CFO + Finance Head. IT_Admin → server access. HR → employee portal only.

→ INTERVIEW TIP: Quarterly Access Review compulsory karo – ex-employees, role changes, excess permissions cleanup.

Q17 MFA kya hai aur isko kyun implement karna chahiye?

✓ ANSWER

MFA (Multi-Factor Authentication) – Multiple verification factors: • Something You Know: Password / PIN • Something You Have: OTP (authenticator app), Hardware token, Smart Card • Something You Are: Biometric (fingerprint, face, iris) Kyun Important: • 80%+ account breaches stolen credentials se hote hain • MFA enable hone par password leak hone ke bawajood account safe • Compliance requirement: ISO 27001, PCI-DSS, HIPAA Where to Apply: VPN access, Admin portals, Email (O365), Cloud (AWS/Azure), Critical systems Tools: Microsoft Authenticator, Duo Security, Google Authenticator, FortiToken

■ EXAMPLE

CEO ka email password phishing se leak hua – attacker login try kiya □ MFA OTP prompt – OTP nahi tha □ Access denied. Account safe!

□ INTERVIEW TIP: Phishing-resistant MFA: FIDO2/WebAuthn (hardware security keys) – OTP se zyada secure. SIM-swapping OTP bypass kar sakti hai.

Q18 Employee resignation ya termination par aap kya security steps loge?

✓ ANSWER

Offboarding Security Checklist: □ Last day par immediately AD account disable karo □ Email account disable / redirect to manager □ VPN access revoke □ All application accounts disable (ERP, CRM, Jira, GitHub, cloud) □ Company devices collect karo □ wipe karo (MDM remote wipe) □ Shared passwords change karo (WiFi, shared accounts) □ Access logs review – koi bulk data download toh nahi? □ DLP alerts check karo – USB, email attachment, cloud upload □ HR se formal security clearance confirmation □ Document karo – timestamp ke saath

■ EXAMPLE

Sales Manager resign kiya □ within 2 hours: CRM, VPN, AD, email sab disabled □ Download logs checked (koi abnormal activity nahi) □ Device collected.

□ INTERVIEW TIP: Privileged users (sysadmin, DBA, developers) ke liye stricter process – notice period mein hi privileges reduce kar do.

Q19 SIEM kya hai aur yeh kaise kaam karta hai?

✓ ANSWER

SIEM (Security Information and Event Management) multiple sources se logs collect, correlate aur analyze karta hai – security threats detect karne ke liye. Data Sources: Firewalls, servers, endpoints, applications, network devices, AD Core Functions: • Log Collection & Normalization: Different formats → common format • Real-time Correlation: Related events ko link karo • Alert Generation: Suspicious patterns par notify karo • Dashboard & Reporting: Visual threat landscape • Compliance Reporting: ISO 27001, PCI-DSS, SOX Popular SIEM Tools: • Enterprise: Splunk, IBM QRadar, Microsoft Sentinel • Open-source: AlienVault OSSIM, Wazuh, ELK Stack SOAR = SIEM + Automation: Repetitive response tasks automate karta hai.

■ EXAMPLE

Same IP se 1000 failed logins in 5 mins → SIEM correlation rule trigger → Alert → Analyst IP block karta hai firewall par → Incident ticket raise.

□ INTERVIEW TIP: UEBA (User and Entity Behavior Analytics) SIEM ka extension hai – insider threat detect karta hai normal behavior se deviation se.

Q20 Incident Response kya hota hai? PICERL Framework explain karo.

✓ ANSWER

PICERL Framework (NIST SP 800-61 based): (P) Preparation: IR plan, runbooks, tools ready, team trained, communication tree (I) Identification: Incident detect karo, severity level assign karo (P1/P2/P3/P4) (C) Containment: Short-term: System isolate, network disconnect Long-term: Root cause fix, lateral movement block (E) Eradication: Malware remove, backdoors close, vulnerabilities patch (R) Recovery: Systems restore, closely monitor, verify clean (L) Lessons Learned: Post-incident report, MTTD/MTTR measure, improvements KPIs: MTTD (Mean Time to Detect), MTTR (Mean Time to Respond)

■ EXAMPLE

Ransomware alert 2 AM → On-call notified (P1) → CISO informed → Affected systems isolated → IR team assembled → Root cause: phishing email → Backup restore.

□ INTERVIEW TIP: Incident Response playbooks/runbooks pehle se banao – pressure mein steps miss ho jate hain. Practice tabletop exercises karo.

Q21 Log analysis kaise karte hain? Suspicious activity ke indicators kya hain?

✓ **ANSWER**

Log Analysis Approach: 1. Centralize: SIEM ya syslog server par aggregate karo 2. Normalize: Different formats → common schema 3. Correlate: Related events timeline mein dekho 4. Alert rules: Known bad patterns par trigger Suspicious Activity Indicators (IoC):

- Multiple failed logins (brute force) – same IP/user
- Login at unusual hours (3 AM) from new location
- Large data transfers to unknown external IPs (exfiltration)
- Port scanning activity on internal network (lateral movement)
- Antivirus/EDR disabled or service stopped
- New admin account created without change ticket
- RDP connections between servers (lateral movement)
- PowerShell encoded commands executed

■ **EXAMPLE**

FortiGate log: ek IP se 500 failed SSH attempts → Brute force alert → IP block kiya → Source investigate kiya → Botnet IP blacklisted.

□ **INTERVIEW TIP:** Log retention: Security compliance ke liye minimum 1 year, some regulations 3–7 years mandate karte hain. Plan accordingly.

06

Vulnerability Assessment & Penetration Testing

Q22 Vulnerability Assessment aur Penetration Testing mein kya fark hai?

✓ **ANSWER**

Vulnerability Assessment (VA):

- Automated scanning se vulnerabilities identify karna
- Non-intrusive – production systems safe rehte hain
- Output: CVE list with CVSS severity scores
- Tools: Nessus, OpenVAS, Qualys, Rapid7 InsightVM
- Frequency: Monthly/Quarterly

Penetration Testing (PT):

- Manual + automated exploitation attempt
- Real attacker simulate karta hai (authorized)
- Scope aur rules of engagement defined hote hain
- Output: Exploited vulnerabilities + business impact + remediation
- Tools: Metasploit, Burp Suite, Nmap, Kali Linux, BloodHound

Testing Types:

- Black Box: No info given (external attacker simulate)
- White Box: Full info (code, architecture – most thorough)
- Grey Box: Partial info (authenticated user simulate)

VAPT = VA + PT combined approach

■ **EXAMPLE**

Quarterly Nessus scan → 3 Critical CVEs (Apache 2.4.x, OpenSSL 1.0) → Patches applied → Rescan → All clear → Compliance report filed.

□ **INTERVIEW TIP:** CVSS Scoring: 0–3.9 Low, 4–6.9 Medium, 7–8.9 High, 9–10 Critical. Critical patches 24–48 hrs mein apply karo.

Q23

Common network vulnerabilities kaunsi hain? Real examples ke saath batao.

✓ ANSWER

Top Network Vulnerabilities: 1. Default Credentials – Admin/admin routers, cameras, switches (most common!) 2. Unpatched Systems – Known CVEs exploited (MS17-010, Log4Shell, ProxyLogon) 3. Unnecessary Open Ports – Telnet (23), FTP (21), RDP exposed to internet 4. Weak/Broken Encryption – MD5, DES, TLS 1.0 still in use 5. Misconfigured Firewalls – "Allow Any Any" rules 6. No MFA on Critical Systems – Single password = single point of failure 7. Rogue DHCP/DNS Servers – Network-level attacks 8. Unencrypted Protocols – HTTP, Telnet, FTP in use 9. Excessive User Privileges – Everyone has admin rights 10. Lack of Network Segmentation – Flat network = lateral movement easy

■ EXAMPLE

Audit mein 12 IP cameras default password (admin/admin) use kar rahi thi – immediately change kiye, separate IoT VLAN mein move kiya.

□ INTERVIEW TIP: CVE database: nvd.nist.gov par check karo. Vendor advisories subscribe karo – FortiGuard, Microsoft MSRC, Cisco PSIRT.

Q24

Nmap kya hai? Important commands explain karo.

✓ ANSWER

Nmap (Network Mapper) ek open-source tool hai network discovery, port scanning aur security auditing ke liye. Essential Commands: • `nmap -sn 192.168.1.0/24` □ Host discovery only (ping scan, no port scan) • `nmap -sV 192.168.1.10` □ Service version detection • `nmap -O 192.168.1.10` □ OS fingerprinting • `nmap -p 22,80,443,3389 192.168.1.10` □ Specific ports scan • `nmap -A 192.168.1.10` □ Aggressive (OS + version + scripts + traceroute) • `nmap --script vuln 192.168.1.10` □ Vulnerability detection scripts • `nmap -sU -p 53,161 192.168.1.10` □ UDP port scan (DNS, SNMP)

■ EXAMPLE

Network audit task: `nmap -sV 192.168.0.0/24` □ 3 servers par port 23 (Telnet) open □ Immediately disable □ SSH enable □ Documented.

□ INTERVIEW TIP: LEGAL WARNING: Nmap sirf authorized/own networks par use karo. Unauthorized scanning illegal hai aur action ho sakta hai.

07

Compliance & Audit

Q25

ISO 27001 kya hai? IT security mein iska importance kya hai?

✓ ANSWER

ISO 27001 ek international standard hai Information Security Management System (ISMS) ke liye – organizations data securely manage kar sake. Key Requirements: • Risk Assessment & Treatment: Threats identify, controls implement • Security Policies: Written, approved, communicated • Access Control: Need-to-know basis • Cryptography: Encryption standards • Incident Management: Detect, respond, report • Business Continuity: DR/BCP plans • Supplier Security: Vendor risk management ISO 27001:2022 mein Annex A ke 93 controls hain (4 themes): Organizational | People | Physical | Technological Certification Process: Gap Assessment □ Implement Controls □ Internal Audit □ Stage 1 Audit □ Stage 2 Audit □ Certification (valid 3 years)

■ EXAMPLE

ISO 27001 audit preparation: Access control matrix update, incident logs review, policy documents sign-off, network diagrams update □ External auditor ne sab verify kiya □ Certification mili.

□ INTERVIEW TIP: ISO 27001 = Framework/Certification. ISO 27002 = Implementation Guidance (controls ka detail). Fark clear rakhna.

Q26

Security audit ke liye aap kya documentation maintain karte ho?

✓ ANSWER

Essential Documentation Checklist: □ Asset Management: • Hardware + Software inventory (CMDB) • Network diagrams (updated) □ Access Control: • User access matrix (who has access to what) • Quarterly access review records □ Change Management: • Change request logs (firewall rules, server config) • Rollback procedures □ Security Operations: • Incident log with timestamps • Patch management records • Vulnerability scan reports □ Compliance: • Security policies (signed by management) • Risk register • Vendor/OEM contracts • Backup success/failure logs

■ EXAMPLE

Surprise audit: Auditor ne last 6 months ke firewall rule changes maange □ Change log mein sab documented tha with timestamps, requester, approver □ Audit smoothly pass.

□ INTERVIEW TIP: CMDB (Configuration Management Database) = single source of truth for all IT assets. ServiceNow popular tool hai.

Q27 GMP environment mein IT ka role kya hota hai? (Pharma/Regulated Industry)

✓ ANSWER

GMP (Good Manufacturing Practice) pharma mein product quality aur safety ensure karta hai. IT ka role:

- Computer System Validation (CSV): Validated systems use karo – IQ (Installation), OQ (Operational), PQ (Performance) qualification
- Data Integrity (ALCOA+ Principle): Attributable | Legible | Contemporaneous | Original | Accurate + Complete | Consistent | Enduring | Available
- Audit Trail: All system changes logged (who, what, when) – tamper-proof, cannot delete
- Access Control: Only authorized users modify manufacturing records
- Change Control: Any system change □ formal change request □ approval □ implementation □ documentation

Regulatory Standards:

- 21 CFR Part 11 (US FDA): Electronic records & signatures
- EU GMP Annex 11: Computerised systems

■ EXAMPLE

FDA audit: Inspector batch record ka audit trail manga □ MES system se full log export kiya – original entry: operator + timestamp, review: QA manager + timestamp □ Data integrity confirmed.

□ INTERVIEW TIP: Ami Polymer pharma/polymer sector mein hai – GMP aur data integrity pe strong answers dena bahut important hai is interview mein.

08

Security Policies, Backup & Disaster Recovery

Q28 Backup strategy kya hoti hai? 3-2-1 rule explain karo.

✓ ANSWER

3-2-1 Backup Rule: 3 □ Teen copies of data (1 primary + 2 backups) 2 □ Do alag media types par (disk + tape OR disk + cloud) 1 □ Ek copy offsite/geographically separate location par

Backup Types:

- Full Backup: Complete data copy. Slow, large size. Weekly.
- Incremental: Last backup ke baad changes only. Fast, small. Daily.
- Differential: Last full backup ke baad changes. Medium. Good restore speed.

Key Metrics:

- RTO (Recovery Time Objective): Kitni der mein recover karna hai?
- RPO (Recovery Point Objective): Kitna data loss acceptable hai?

Best Practice: Air-gapped backup (network se disconnected) = ransomware-proof

■ EXAMPLE

Daily incremental (2 AM), Weekly full (Sunday), Monthly offsite cloud (Azure Backup). Ransomware attack Monday morning □ Sunday full backup se restore □ RPO: ~12 hrs, RTO: 4 hrs.

□ INTERVIEW TIP: Backup without restore test = useless. Monthly restore drill karo. "Backup is not DR, DR is a process."

Q29

BCP aur Disaster Recovery (DR) mein kya fark hai?

✓ ANSWER

BCP (Business Continuity Plan): • Broad plan: Entire business operations disruption mein continue kaise kare • Includes: IT + HR + Communication + Alternate workspace + Supply chain • Focuses on: People, Process, Technology sabka continuity DR (Disaster Recovery): • Specific IT plan: Systems aur data ko restore karna • Subset of BCP DR Site Types: • Hot Site: Fully operational, immediate failover (minutes), most expensive • Warm Site: Partially equipped, few hours to restore, moderate cost • Cold Site: Basic infra, days to restore, cheapest DR Testing Methods: • Tabletop Exercise: Discussion-based walkthrough • Parallel Test: DR site activate karo, primary bhi running • Full Failover Test: Primary shut karo, DR se run karo (most realistic)

■ EXAMPLE

Datacenter fire □ BCP activate □ Staff home se remote kaam □ Cloud DR site pehle se active □ Customers unaffected □ 2 hours mein fully operational.

□ INTERVIEW TIP: Annual DR drill mandatory hai. Document karo – actual RTO vs planned RTO compare karo aur improve karo.

Q30

Security policies kaise implement aur enforce karte hain?

✓ ANSWER

Security Policy Lifecycle: 1. CREATE: Risk assessment se driven, management approval, legal review 2. COMMUNICATE: All-hands training, email, acknowledgment sign-off 3. ENFORCE (Technical Controls): • Password Policy □ GPO (12 chars, complexity, 90-day expiry) • Screen Lock □ GPO (5 min idle) • USB Disable □ GPO / Endpoint DLP • Internet Policy □ Firewall Web Filter • Email Policy □ Exchange / O365 DLP 4. MONITOR: SIEM alerts, audit logs, compliance dashboard 5. REVIEW: Annual review, update for new threats/regulations Key Policies: Acceptable Use | Password | Access Control | Incident Response | BYOD | Remote Work | Vendor Access

■ EXAMPLE

Password policy GPO deploy kiya □ Users complain kiya complex password yaad nahi hota □ Password manager (Bitwarden) recommend kiya □ Security + Usability balance.

□ INTERVIEW TIP: Policy sirf paper par nahi honi chahiye – "policy without enforcement is just a wish list." Technical controls se enforce karo.

09

HR & Behavioral Questions

Q31

"Tell me about yourself" – Best answer structure kya hai?

✓ ANSWER

PRESENT □ PAST □ FUTURE Structure (2-3 minutes): PRESENT (current role): "Main currently [Company] mein Senior IT Engineer hoon, jahaan main network security, firewall management, VPN aur Active Directory handle karta hoon. FortiGate NGFW, server administration aur endpoint security mera core expertise hai." PAST (background): "Maine 4+ saal mein networking aur security mein hands-on experience build kiya hai. MCA [University] se kiya, aur currently CompTIA Security+ aur VMware certifications pursue kar raha hoon." FUTURE (why this role): "Main Network Security mein further specialize karna chahta hoon – threat detection, compliance aur incident response mein grow karna goal hai. Ami Polymer ka regulated environment aur security-focused role mere career goals ke saath perfectly align karta hai."

■ EXAMPLE

Ami Polymer pharma/polymer company hai – interview se pehle company research karo: what they manufacture, their compliance requirements (GMP), company size.

□ INTERVIEW TIP: Memorize mat karo – natural raho. Practice karo lekin conversational tone rakho. 2-3 minute se zyada mat bolo.

Q32

Ek security incident describe karo jo aapne handle kiya. (STAR Method)

✓ ANSWER

STAR Framework: S – SITUATION (Context): "Ek Monday morning suddenly 40+ users ne complaint ki ki internet extremely slow hai aur kuch systems unresponsive hain." T – TASK (Responsibility): "Mere responsibility thi network investigate karna, root cause identify karna aur minimum downtime mein resolve karna." A – ACTION (What you did): "FortiGate logs check kiye – ek PC se unusual outbound traffic tha (500MB/hr to unknown IP). Wireshark se confirm kiya – bot malware active tha. Immediately system isolate kiya, malware remove kiya, full network scan run kiya, USB policy tighten ki, user awareness email bheja." R – RESULT (Measurable outcome): "2 hours mein network normal hua. No data breach. Incident report filed. USB policy GPO se enforce ki. Security awareness training scheduled."

■ EXAMPLE

Apna real experience tailor karo STAR format mein. Agar direct incident nahi, training/lab scenario bhi dena honestly with disclosure okay hai.

□ INTERVIEW TIP: ALWAYS measurable result batao – "network normal hua" se better hai "within 2 hours, with zero data loss." Numbers impress karte hain.

Q33

Security aur business needs mein aap balance kaise rakhte ho?

✓ ANSWER

Security vs Usability – Classic Tension: Approach: 1. Risk-Based Decisions: Har control ka business impact assess karo 2. Explain Don't Just Restrict: Business ko risk + consequences explain karo 3. Offer Alternatives: "No" nahi bolte, better solution suggest karte hain 4. Tiered Controls: Critical systems strict, general systems balanced 5. User Training: Employees ko security partners samjho, obstacles nahi 6. Executive Buy-in: Management support zaroori hai security culture ke liye Principle: "Security should enable business, not disable it."

■ EXAMPLE

Business ne bola "VPN slow hai, hata do." Mein ne data breach risk + cost explain kiya, phir split tunneling implement kiya – only work traffic VPN se, rest directly □ 60% speed improvement, security maintained.

□ INTERVIEW TIP: Never be the "Department of No." Always come with solutions. Security professionals jo business language bolte hain – unhe zyada respect milta hai.

Q34

Latest security threats ke baare mein aap kaise updated rehte ho?

✓ ANSWER

Continuous Learning Sources: □ Threat Intelligence: • CISA Alerts (cisa.gov/alerts) • US-CERT / NVD (nvd.nist.gov) • FortiGuard Threat Intelligence □ Security News & Blogs: • The Hacker News (thehackernews.com) • Bleeping Computer • Krebs on Security • Dark Reading □ Learning & Certifications: • CompTIA Security+, CEH, CISSP study • TryHackMe, Hack The Box labs • Vendor training: Fortinet NSE, Microsoft SC-200 □ Community: • LinkedIn security groups • Local OWASP/ISACA chapter events

■ EXAMPLE

Last month FortiGuard ne CVE-2024-XXXX FortiOS vulnerability alert diya □ Immediately version check kiya □ Patch available tha □ 24 hours mein emergency maintenance window leke apply kar diya.

□ INTERVIEW TIP: Genuine curiosity dikhao – "main daily 30 min security news padhta hoon" specific aur credible lagta hai. Vague "I keep myself updated" se bachna.

10

Rapid Fire Q&A – Quick Technical Questions

Yeh questions interview mein jaldi-jaldi pooche jaate hain. Short, confident aur accurate answer dena hai.

Q35

HTTP aur HTTPS mein kya fark hai?

□ HTTP unencrypted (port 80) – data plaintext jaata hai. HTTPS TLS/SSL encrypted (port 443) – Man-in-the-Middle attack prevent karta hai. Always HTTPS use karo.

Q36 Key ports batao: SSH, Telnet, SMTP, DNS, HTTP, HTTPS, RDP

□ SSH=22 | Telnet=23 (insecure, avoid) | SMTP=25 | DNS=53 | HTTP=80 | HTTPS=443 | RDP=3389 | SFTP=22 | LDAP=389 | LDAPS=636

Q37 ARP kya karta hai?

□ ARP (Address Resolution Protocol) IP address ko MAC address mein convert karta hai same network segment mein. ARP Spoofing = Man-in-the-Middle attack vector.

Q38 Social Engineering kya hota hai? Types batao.

□ Technical nahi, human psychology exploit karna. Types: Phishing (email), Vishing (voice/call), Smishing (SMS), Pretexting (fake scenario), Baiting (USB drop), Tailgating (physical access).

Q39 Zero Trust Architecture kya hai?

□ "Never Trust, Always Verify." Koi bhi user/device inherently trusted nahi – chahe internal network mein ho. Identity verify karo, least privilege do, micro-segment karo, continuously monitor karo.

Q40 DLP kya hai?

□ Data Loss Prevention – sensitive data (PII, financial, IP) ko unauthorized access ya leak se protect karna. Types: Network DLP (email/web), Endpoint DLP (USB/print), Cloud DLP (SaaS).

Q41 Honeypot kya hota hai?

□ Decoy system jo attackers attract karta hai. Attacker ka behavior study karte hain, real systems safe rehte hain. Production network se isolated rakhna zaroori hai.

Q42 DMZ kya hai aur kisko rakhte hain?

□ De-Militarized Zone – public-facing servers ka buffer network zone. Web servers, Mail relay, Public DNS rakhte hain. Internet se accessible lekin internal LAN se isolated. Two firewalls se protected.

Q43 Encryption aur Hashing mein kya fark hai?

□ Encryption: Reversible (decrypt ho sakta hai) – AES-256, RSA. Data confidentiality ke liye.
Hashing: One-way (reverse nahi) – SHA-256, bcrypt. Password storage + data integrity ke liye.

Q44 Ransomware se bachne ke top 3 practices?

□ 1) Regular air-gapped backups (offline/offsite). 2) Email security gateway + attachment sandboxing. 3) User awareness training – phishing links nahi kholna. Bonus: Patch management + Least privilege.

Q45 SSL Certificate kya hota hai?

□ Digital certificate jo website ki identity verify karta hai aur HTTPS encryption enable karta hai. CA (Certificate Authority) issue karta hai – DigiCert, Let's Encrypt. Expired cert = browser warning.

Q46 NAC kya hai?

□ Network Access Control – unauthorized/non-compliant devices ko network join karne se rokta hai. Device health check: antivirus updated, OS patched, compliance verified. Posture assessment karta hai.

Q47 OWASP Top 10 kya hai?

□ Web application security risks ki annually updated list. Top risks: Broken Access Control, Cryptographic Failures, Injection (SQLi), Insecure Design, Security Misconfiguration, XSS, SSRF. Developer security ka reference standard.

Q48 Koi real security tool ka naam lo jo aapne personally use kiya.

□ FortiGate (firewall policy, VPN, IPS), Wireshark (packet capture), Nmap (network scan), Active Directory (user management), Event Viewer (Windows logs). Agar Nessus/OpenVAS experience ho toh mention karo.

Q49 Ek network pe Telnet open port mila – aap kya karoge?

□ Immediately disable karo – Telnet unencrypted hai, credentials plaintext jaate hain. SSH (port 22) configure karo as replacement. Change log mein document karo. Network audit report mein include karo.

Q50 Apni sabse badi professional strength ek line mein batao.

□ "Main network security ko technically strong aur business-aligned tarike se handle karta hoon – incidents fast resolve karta hoon, documentation properly maintain karta hoon, aur continuously seekhta rehta hoon."



All The Best, Akhilesh!

Aap ready hain – confidence ke saath interview do.

▣ Research Ami Polymer before interview

▣ Prepare 2-3 real incident stories (STAR)

▣ Know your resume deeply – every line

▣ Ask smart questions at the end

▣ GMP/compliance awareness dikhao

▣ Dress professionally, arrive 10 min early

Prepared by Akhilesh Choudhary | TechShiksha | akhileshchaudhari.com | [@akhilesh.webdev](https://twitter.com/akhilesh.webdev)